

# 7.15 E-R audit — embedded calls on the split D stack

## 1. Identity and scope

Sole audit agent: Codex. Worktree /private/tmp/kk715-er, branch release/715-stack-07b3r-erc7730-embedded. Owner authorized carrying E onto D-G/D-I on 2026-09-27. Base: D-I firmware PR #869, 966c69b6fea4c223b51a5018ba6b9134374c0699. Code snapshot: 25d14f433a46144cc6b554c0ae57b62455dbd487. Python companion PR #119 pins 8a213ecb3ebf3db45b7a4934437a74e7cf067b1f. All other dependency pins remain as listed in the D-G report. Canonical release/7.15 is not updated. Historical firmware PR #867 and Python PR #116 remain preserved. This is a code-bearing adjacent embedded-call unit.

The device binds an inner definition to decoded chain, callee and selector. Unsupported calls are refused or explicitly shown blind. Outer state and replay remain bound to the transaction. Depth-two and calls within iteration retain the documented bounded fallback. D-G and D-I behaviors and new regressions remain present. This child does not accept either predecessor's review.

## 2. Adjacent inventory

Code range 966c69b6f..25d14f433. Report predecessor and containing final SHA are recorded in the PR body. The final table includes all paths and exact source line count; PDF counts are binary. Historical report paths remain on their old drafts and are mapped in the new resplit receipt.

| Tracked path                                                   | Added | Deleted | Change and evidence                                      |
|----------------------------------------------------------------|-------|---------|----------------------------------------------------------|
| .github/workflows/ci.yml                                       | 1     | 1       | Changed as part of this bounded audit unit.              |
| deps/python-keepkey                                            | 1     | 1       | Pins the matching compiler mirror and its tests.         |
| docs/release/audit-units/715-07b-resplit-checks-20260927.json  | 31    | 0       | Records exact scope, findings, inventory and validation. |
| docs/release/audit-units/715-07b-resplit-receipt-20260927.md   | 74    | 0       | Records exact scope, findings, inventory and validation. |
| docs/release/audit-units/715-07b3r-embedded-audit-20260927.md  | 131   | 0       | Records exact scope, findings, inventory and validation. |
| docs/release/audit-units/715-07b3r-embedded-audit-20260927.pdf | -     | -       | Rendered audit evidence from the adjacent source report. |
| docs/security/HANDOFF-ERC7730-715-FORMATTERS.md                | 10    | 9       | Records on-screen behavior and fail-closed limits.       |
| docs/security/HANDOFF-ERC7730-PHASE-E.md                       | 209   | 0       | Records on-screen behavior and fail-closed limits.       |
| include/keepkey/firmware/erc7730_abi_stream.h                  | 8     | 1       | Declares bounded state and the phase's runtime contract. |
| include/keepkey/firmware/erc7730_capabilities.h                | 17    | 7       | Declares bounded state and the phase's runtime contract. |
| include/keepkey/firmware/erc7730_catalog.h                     | 9     | 5       | Declares bounded state and the phase's runtime contract. |
| include/keepkey/firmware/erc7730_field.h                       | 9     | 0       | Declares bounded state and the phase's runtime contract. |
| include/keepkey/firmware/erc7730_workflow.h                    | 49    | 1       | Declares bounded state and the phase's runtime contract. |
| lib/firmware/erc7730_abi_stream.c                              | 13    | 2       | Captures only bounded ABI facts and records overflow.    |
| lib/firmware/erc7730_capabilities.c                            | 19    | 6       | Selects the exact formatter and display capabilities.    |

| Tracked path                                 | Added | Deleted | Change and evidence                                      |
|----------------------------------------------|-------|---------|----------------------------------------------------------|
| lib/firmware/erc7730_catalog.c               | 29    | 8       | Refuses unexecutable signed programs before review.      |
| lib/firmware/erc7730_field.c                 | 42    | 0       | Formats decoded values with signer provenance visible.   |
| lib/firmware/erc7730_workflow.c              | 243   | 7       | Keeps replay, validation and UI state in sequence.       |
| lib/firmware/fsm.c                           | 2     | 1       | Implements the phase's bounded decoding or display rule. |
| lib/firmware/fsm_msg_ethereum.h              | 268   | 26      | Shows and confirms the device-decoded review screens.    |
| scripts/emulator/test_stack07_regressions.py | 6     | 503     | Exercises signed wire requests and review screens.       |
| unittests/firmware/erc7730_catalog.cpp       | 277   | 174     | Covers accepted neighbors and fail-closed boundaries.    |
| unittests/firmware/erc7730_field.cpp         | 24    | 0       | Covers accepted neighbors and fail-closed boundaries.    |
| unittests/firmware/erc7730_workflow.cpp      | 9     | 5       | Covers accepted neighbors and fail-closed boundaries.    |

ABI capture identifies inner calldata and context. Catalog formatter flags validate amount/callee/value availability; field/workflow code binds inner review and restores the outer definition. FSM dispatch requests matching inner programs, distinguishes clear and blind screens, and cancels without signing. Runtime cases move into the Python suite for release-report screenshots.

### 3. Reconciliation and findings

Production firmware include/lib trees exactly equal old E ed18a68e1. Production Python keepkeylib exactly equals validated fb94c5c. New controls are the retained group frame regression, signer-constant intent contract, and nested optional-group wire test. E already destructures the tuple correctly, so carrying D-I's host repair introduces no new E production change.

| Finding/class                         | Disposition                                                                                            |
|---------------------------------------|--------------------------------------------------------------------------------------------------------|
| D2 embedded intent, D9 literal callee | Bind inner review to decoded chain/callee/selector; mismatch refuses                                   |
| D17 refused inner definition          | Unsupported inner programs cannot create a trusted screen; fallback explicitly warns blind             |
| Missing amountPath                    | Never invent inner @.value; reject unsupported inner value use                                         |
| Depth/call binding                    | Bound depth, capture offsets, outer restoration and signed replay; exact neighbor tests retained       |
| D15 continuation handling             | Filter continuation pages while retaining duplicate screen content                                     |
| Mixed-array integration               | Same tuple array accepted for embedded callee/data; separate arrays refuse before preload              |
| Screenshot EX33/EX16                  | No screen declared for preload refusal; fixed/dynamic element screens retained                         |
| New EX39                              | Retained D-G nested optional fields, zero and nonzero values; report now declares its captured screens |
| Historical evidence gap               | Raw 42-row ledger and D13/D19 not retained; no invented dispositions                                   |

Source audit revisited binding, outer restoration, capture offsets, absent value refusal, depth/iteration fallback, cancellation and formatter flags. No new E production defect was confirmed. All 18 relocated D-I wire methods are accounted for in Python, with one existing native-alias rename. Removing the group method fails the relocation check. The adjacent JSON records source identities and method mapping. All native D-G/D-I regressions survive; E adds four native cases.

## 4. Verification and artifacts

Pinned image digest 7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Registry pin 9f37816afde954ff6617fb5baa346133e5af26c5. Local runs use the code snapshot and Python pin above, with only report/workflow provenance edits after validation. Native and wire run sequentially.

| Check                              | Result                | Evidence/limit                                                                        |
|------------------------------------|-----------------------|---------------------------------------------------------------------------------------|
| Full native                        | 657 passed            | er-native.xml; includes retained frame regression                                     |
| Compiler/catalog/report validation | 35 passed, zero skips | er-compiler.xml; 1,450 registry formats, 1,297 signable                               |
| Wire/runtime                       | 60 passed             | 21 Stack07 and 39 runtime cases; no overlap summed                                    |
| EX39 capture                       | 1 passed; 6 PNGs      | one manifested sequence, exact recipient/amount/fee assertions                        |
| Production equivalence             | passed                | old E firmware and Python library comparison                                          |
| Relocation negative control        | expected failure      | missing group method makes coverage incomplete                                        |
| Exact-head CI                      | pending at freeze     | both ARM/native variants, integration, screenshots and report/evidence gates required |
| Physical device                    | not performed         | release gate remains pending                                                          |

Old E CI 36290055140 passed on ed18a68e1; downloaded manifest bound that head, Python fb94c5c, companion PR #116 and run URL; PDF hash matched and four corrupted provenance fields were rejected. This supports equivalence but does not replace E-R exact-head CI with the new pins, reports and workflow URL.

## 5. Report and preflight

Source and PDF rendered together; every page visually inspected. Final adjacent inventory and numeric counts must match Git. Code-bearing gate passes and its empty-diff negative control fails. Canonical preflight retains the previously owner-authorized inherited duplicate options, missing report-gate test and cppcheck build-directory error; it is recorded as failed. Hosted static and report/evidence gates must pass for the final head before a review request.

## 6. Retrospective and review checkpoint

Zero replacement Copilot attempts at freeze; maximum three. D-G and D-I have separate budgets; old D receives no fourth request. The resplit exposed a host mirror tuple-index bug and a stale refusal expectation; both are fixed in the owning children and regression coverage survives E recombination. New reports use adjacent boundaries and measured counts. Historical reports remain dated evidence and are not silently presented as current acceptance. Current head, CI, manifest checks and review state belong in the live PR description. No merge, release promotion or physical-device acceptance is claimed.